SECURITY ENGINEERING CASE STUDY · V0.9

Cloud-Native Incident Response

Evidence correlation, production-safe investigation and defensible security decision-making.

Sanitized Professional Case Study

Professional context: FoundLab. This public candidate does not reproduce a private project, client, production environment, internal architecture, ticket, raw log, proprietary source code, or non-public finding.

PUBLICATION PRINCIPLE

Preserve the engineering value, remove the environment. This edition retains methodology and decision logic while replacing operational details with generic or synthetic equivalents.

DATE	7 October 2026
DOCUMENT	PORTFOLIO-IR-20261007
STATUS	Author-confirmed permission to publish sanitized edition
AUTHOR	Gabriel Barbosa - Cybersecurity Engineer · FoundLab

REVIEW STATUS | No signed reviewer attestation claimed

CLASSIFICATION | Public - generalized / synthetic case study

Executive Summary

A public, sanitized case study demonstrating evidence-first incident response without exposing private operational details.

This document presents a sanitized security-engineering case derived from professional incident-response methodology. It demonstrates how an unusual cloud event can be investigated without converting suspicion into unsupported certainty. All production identifiers, timestamps, endpoints, provider case data, people-specific administrative activity and internal architecture have been removed or replaced.

SECURITY-RELEVANT SIGNAL **Observed**	CONTROL OUTCOME **Denied / fail-closed**
COMPROMISE **Not established**	EXFILTRATION **Not established**
UNAUTHORIZED PERSISTENCE **Not established**	CAUSAL ATTRIBUTION **Not claimed**

DEFENSIBLE CONCLUSION

A security-relevant event can be real, processed and denied without proving compromise. The correct conclusion is bounded by the evidence actually collected. Unknown remains an acceptable state when the available telemetry cannot support stronger attribution.

The public edition intentionally avoids exact dates, addresses, service names, cloud resource identifiers, credentials, IAM grants, repository information, screenshots, raw telemetry and vendor support references. These omissions are a security control, not a gap in the case-study methodology.

02 · PUBLICATION SCOPE

Sanitization & Publication Boundary

What is intentionally removed, what is transformed, and what remains useful for technical review.

CATEGORY	PUBLIC TREATMENT	REASON
Organization context	FoundLab retained only as professional affiliation	Affiliation is distinct from project attribution.
Project / product names	Removed or replaced with generic terms	Prevents reconstruction of internal systems.
Cloud identifiers	Removed	No project numbers, resource IDs, revisions or account identifiers.
Network / request data	Removed or synthesized	No IPs, hostnames, endpoints, referers, request IDs or traces.
Administrative activity	Generalized	No employee-specific IAM actions, e-mails or exact role grants.
Provider alerts / tickets	Generalized	No support case numbers, abuse labels or private correspondence.
Evidence screenshots	Recreated as diagrams	Avoids accidental disclosure embedded in images.
Methodology	Preserved	Evidence states, investigation order and decision logic remain inspectable.

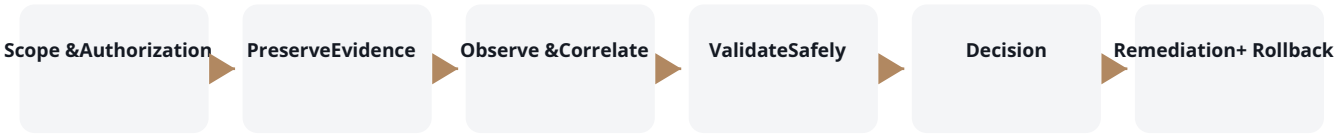
NO ATTRIBUTION TO A PRIVATE PROJECT

Nothing in this edition should be interpreted as a diagram, finding, incident record, log extract or control implementation from a FoundLab private system. Technical patterns are intentionally vendor-neutral and sanitized.

03 · METHOD

Evidence First / Production Safe

The investigation model separates observation, validation, inference and authorized remediation.



The core discipline is to preserve and understand before changing. Production is treated as a source of evidence, not a laboratory. Read-only collection and local analysis are preferred before any mutating action; containment is proportional to demonstrated risk and must have an authority boundary.

Evidence states

STATE	MEANING
OBSERVED	Directly present in collected evidence.
VERIFIED	Independently corroborated by another trustworthy source or control.
INFERRED	Supported indirectly, but not directly demonstrated.
UNVERIFIED	Not demonstrated with the available evidence.
INCONCLUSIVE	Evidence cannot establish a reliable outcome in the defined scope.

> **DECISION DISCIPLINE**
>
> Documentation, source code, test output and observed production behavior are different evidence layers. One must not silently substitute for another. Severity and confidence are recorded separately.

04 · SANITIZED TIMELINE

Correlated Event Timeline

Relative time preserves the reasoning sequence while removing operationally sensitive timestamps and identities.

T-2d	**Administrative context**	Authorized access changes and routine operational activity are recorded.
T0	**Security-relevant request**	An unusual request reaches a protected cloud application path.
T+~1m	**Application decision**	A downstream dependency fails; the application denies the operation rather than continuing permissively.
T+hours	**External signal**	An external security signal increases investigation priority but does not identify a definitive cause.
T+hours	**Evidence collection**	Request, application, identity and control-plane telemetry are correlated using safe read-only queries.
T+1d	**Decision point**	No successful exploitation, unauthorized persistence or exfiltration is established in the reviewed evidence set.

CORRELATION CONTROL

Repeated or correlated telemetry can demonstrate that events share a technical context. It does not, by itself, identify the final person, device or intent behind an action. Attribution requires stronger evidence.

05 · EVENT ANALYSIS

Fail-Closed Security Behavior

The public case retains the security property while abstracting implementation-specific paths, identities and dependencies.

INPUT CONTEXT	IDENTITY CONTROL
Authenticated request	**Trusted context prevails**
DOWNSTREAM CONDITION	APPLICATION OUTCOME
Dependency failure	**DENY / no success**



OBSERVED SECURITY PROPERTY

In the representative event model, untrusted request metadata does not override authenticated context, and downstream failure does not become permissive execution. The operation terminates denied and produces security-relevant evidence. This demonstrates fail-closed behavior for the tested condition, not universal assurance.

A model, service, dependency or external component may fail in many ways. A defensible control claim is scoped to the exact condition and evidence tested. The public case therefore avoids statements such as “the system is secure” and instead records the specific invariant that remained preserved.

06 · CONTROL PLANE

Administrative Correlation

Control-plane evidence is evaluated independently from the application request so that routine administration is not mistaken for compromise.

QUESTION	PUBLIC EVIDENCE MODEL	DECISION RULE
Identity changes	Correlate policy changes to authorized operators and change context.	Unknown or unexplained principals require escalation.
Persistent credentials	Enumerate durable credentials and compare with expected inventory.	Unexpected durable credentials raise persistence concern.
Compute / workload inventory	Review for resources inconsistent with the known environment.	Unexpected resources require historical correlation.
Privileged actions	Correlate principal, timestamp, user agent and intended task.	Authorization must be evidenced, not assumed.
Data access	Use available audit evidence to test unauthorized read/write hypotheses.	Absence in one log source is not proof of absence.
Supply chain	Compare reviewed artifact to deployment evidence when available.	Documentation alone cannot prove deployed code identity.

SANITIZED RESULT

Within the bounded evidence set represented by this case, unauthorized administrative persistence was not established. This statement is intentionally narrower than claiming that compromise was impossible or universally absent.

07 · ASSESSMENT

Conclusion, Confidence & Limitations

The case separates what can be stated from what remains unknown.

CLAIM	STATE	WHAT THE EVIDENCE SUPPORTS
Security-relevant request existed	OBSERVED	The event entered the protected workflow.
Operation completed successfully	NOT ESTABLISHED	The representative workflow terminates denied.
Compromise occurred	UNVERIFIED	No sufficient evidence to make that attribution.
Data exfiltration occurred	UNVERIFIED	No sufficient evidence in the reviewed evidence model.
Unauthorized persistence occurred	NOT ESTABLISHED	No demonstrated persistence in the bounded review.
External signal and request share one cause	UNVERIFIED	Correlation is not causation without stronger provider evidence.

Limitations

1. Logging is conditioned by retention, scope, filters and the services that actually emit telemetry.
2. Inventory describes observed state and does not automatically reconstruct every ephemeral historical resource.
3. Network addresses, user agents and similar metadata are correlation signals, not standalone human attribution.
4. This document is a sanitized portfolio artifact, not a forensic chain-of-custody package or legal attribution.
5. Any stronger conclusion would require additional evidence from authoritative sources.

KEY LESSON

Unknown is acceptable. Unsupported certainty is not. A strong incident-response record makes uncertainty visible, documents the evidence boundary and defines the next safest validation step.